

HSDC CYBERSECURITY HANDBOOK- PHISHING EMAIL PACKAGE

HSDC Happy Students Daycare

Date Completed: December 8, 2025

Date Revised: December 7, 2025

Version: 1

Designed by: CyberJericho -Joelle Waugh, Cybersecurity Consultant

Exercise Location: HSDC

Contact: 1-800-111-2222

**** Confidential (Management and Facilitator Copy) ****

This scenario and the accompanying documents contain highly sensitive data for internal use only.

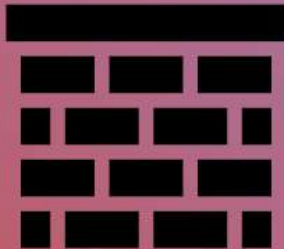
Table of Contents

HAPPY STUDENTS' DAYCARE NIST ASSESSMENT - PHISHING EMAIL.....	5
NIST Assessment Framework.....	6
HAPPY STUDENTS' DAYCARE PLAYBOOK- PHISHING EMAIL.....	8
Introduction	9
Detection and Analysis.....	10
Classification	10
Information Gathering (Level 1 Response)	11
Information Gathering (Level 2 Response)	11
Information Gathering (Level 3 Response)	11
Escalation Decisions	11
Mitigation and Containment.....	12
Pre-Approved Communication Templates	13
Business Continuity Plan	15
Recovery and Return to Normal Operation	16
HAPPY STUDENTS' DAYCARE TABLETOP EXERCISE- PHISHING EMAIL.....	17
Tabletop Objectives	18
Building Resilience	18
Exercise Structure	18
Exercise Guidelines	18
Incident Response Participants.....	19
Exercise Overview	20
Scenario Overview	21
Scenario.....	21
Technical Information	21
Phishing Emails Instructions (Facilitator Only).....	21
Discussion Questions	21
Facilitator Notes and Response Plan to Scenario	22
Hot Wash/After Action review.....	23
After Action Report (Facilitators Only)	24
References	25
Appendix A.....	26

Appendix B.....	27
Appendix C.....	28
Appendix D.....	29
Appendix E	30

CyberJericho

- + Here to Protect, to Serve and to Guide.
- Building your organization stronger with Joelle Waugh.



0

This Document is tailored to your organization's needs.

Have questions?

Contact me: 1-800-111-2222

Please provide feedback!

HAPPY STUDENTS' DAYCARE NIST ASSESSMENT- PHISHING EMAIL

PART 1

NIST Assessment Framework

The NIST Self-assessment test is an excellent way for your organization to assess its security maturity. This is a great way to make improvements and changes that will help succeed in the future. There is a series of questions and a scoring system that is explained below. You can print out page 7, and management can complete the assessment.

A digital copy is available at jw@cyberjericho.com.

Scoring System:

Current State
1 = Not in Place: Need to develop a Training Program that covers role-based, third-party and employee training.
2 = Somewhat in Place: has some training and employees have some awareness, but it is not consistent.
3 = Mostly in Place: has regular training, which covers some training gaps and trains employees and third parties.
4 = Completely in Place: has a comprehensive Cybersecurity training program, and all roles have their appropriate training.
Target State
1 = Minimal Target: Basic and simple training
2 = Moderate Target: has some training
3 = Advanced Target: In good standing with good training capabilities
4= Desired Target: The training is complete with continuous development.

After completing the Current state and Target state, find the difference between them with Delta and add the score; the lower the better.

Objectives	Questions/Evidence	Explanation	Current State	Target State	Delta	Score	Comments
All staff understand cybersecurity risk and know the importance of protecting children's and their families' information.	Is cybersecurity training provided to new employees during the onboarding process?	These questions are essential to ensure that new employees are being trained and are unaware of the company's security standards.					
	How often is training material revised to keep up to date with Cybersecurity threats?						
	Is cybersecurity training tracked and reviewed with employees?						
	Do employees understand and comprehend cybersecurity policies and						
	Do employees participate in simulated exercises?						
Staff who have privileges such as Head of IT, Executive Director, Human Resources and Team leads need to understand the extra security responsibility.	Is management given additional information security training beyond the standard employee training?	These questions ensure that IT professionals and users with privileges maintain proper security practices.					
	Do privileged users understand the responsibilities that come with elevated rights?						
	Do privileged users follow a process to verify their privileges?						
	Are privileged accounts monitored for unusual activity, and is there a process for reporting it?						
	Are there refresher trainings for system configurations or policy changes?						
Ensure the CEO understands their role and is targeted on cyber threats and security responsibilities.	Do senior executives receive unique Cybersecurity training and tailored briefings regarding Cybersecurity events?	These questions ensure that Leadership of the company are following the security practices and are aware of the risk they are involved in.					
	How often do senior executives participate in tabletop exercises and simulations?						
Ensure that any third-party companies and contractors follow proper security practices.	Do third-party stakeholders receive cybersecurity training at their companies before accessing organizational systems?	These questions ensure the company is doing their due diligences when entrusting their customers data or services to third-party companies to ensure that they meet the proper security standards.					
	How often do stakeholders do simulation and tabletop exercises?						
	Do the Stakeholders follow a cybersecurity protocol or policies?						
	What are stakeholders' policies and procedures for handling sensitive information? Is security training monitored and enforced?						
Ensure all staff understand that physical security and Cybersecurity work together.	Do third-party stakeholders and employees receive training on both physical security and cybersecurity?	These questions address the employees and third party to deal with Cybersecurity events. It is to demonstrate that the training is equipping individuals to react in a secure manner.					
	Do employees receive training on recovery and procedures?						
	Are physical security staff trained to deal with incidents and recovery?						
	Are cross-functional exercises conducted to test collaboration between physical and cyber teams during recovery?						
	Are there refresher trainings for system configurations or policy changes during incidents?						

HAPPY STUDENTS' DAYCARE PLAYBOOK- PHISHING EMAIL

PART 2

Introduction

Happy Student Daycare is a well-established Daycare facility in the Peterborough area. The company has 12 physical daycares across Peterborough that serve all ends of the city. In total, the daycare has 20 full-time staff members who are well-equipped to show care and kindness to all the children who enjoy a safe Daycare space. To maintain Happy Student Daycare's strong reputation in the Peterborough area, its Cybersecurity practices will be improved to ensure the well-being and safety of all.

Some of the risks that Happy Students Daycare faces include data breaches due to a lack of device management and the potential entry point via a phishing email. This playbook will help staff understand the risks and what to do in the event of a data breach caused by a phishing email.

What is a data breach?

A data breach is a security incident in which unauthorized parties gain access to sensitive or confidential information. Sensitive and confidential information includes personal, corporate, and highly protected data that is not supposed to be public (Kaspersky, 2025). It becomes a data breach when that information is shared or seen without authorization. A data breach can also be a cyberattack, meaning a threat actor steals, destroys, or disables data, or gains unauthorized access (Kosinski, 2025).

Data breaches can be carried out externally by threat actors or individuals attempting to commit a criminal offence, such as a cyberattack. They can also occur internally within a company, and may be caused by outdated software or an incorrect system security configuration.

Here are some terms and examples of what constitutes a data breach:

- **An Innocent Insider:** An employee who innocently makes a mistake that can be deemed a data breach (Kaspersky, 2025). For example, an employee mistakenly sends the wrong login credentials to another employee.
- **An insider threat:** A disgruntled employee who was laid off, terminated, or is angry at the company, causes a data breach to harm an individual or the company as revenge (Kaspersky, 2025). For example, an angry employee who hears about the upcoming layoffs decides to sell the company's intellectual property to competitors.
- **Lost or Stolen Company Devices:** Unencrypted PKR devices, such as laptops, mobile phones, and USB drives, without proper protection, can be easily read, used, and published by the individual who gains access to the lost or stolen devices (Kaspersky, 2025).
- **Hackers:** malicious threat actors who prepare various attacks to gain unauthorized access to data to sell or perform other attacks, such as information gathering, ransom attacks, and network attacks. This would constitute a cyberattack; however, a hacker of this nature could also gather information from an individual (Kosinski, 2025).

The most common ways that data breaches occur are:

- **User Behaviour:** This is often underrated, but employees and users can give away information to the wrong individuals due to unconscious errors.
- **Phishing:** These emails are designed as social engineering attacks that trick users into clicking on malicious links or providing sensitive data. The attacker pretends to be a legitimate source; in other words, it is a scam (Kaspersky, 2025).

- **Brute-force attack:** An attacker uses technical tools to gain user credentials (Kaspersky, 2025).
- **Malware:** Some hackers may leave specific malicious software that performs various tasks, such as using SQL injections to gather information or zero-day attacks.

What is Device Management and its importance?

Device management is crucial to keeping hardware and software up to date. This includes the physical computers, mobile devices and Internet of Things devices. This is an important part of an organization's security posture and ensures that customers' and employees' data is safe and compliant with the organizational policies (Microsoft Intune, 2025).

It is important to note that not all data breaches are the result of cyberattacks. The incident responder must identify the different levels of data breaches and take the appropriate actions before deeming an incident a cyberattack.

Detection and Analysis

Data breach detection can vary and be complex. Due to the nature of data breaches, it is crucial to analyze for anomalies, which may indicate a compromise. The NIST framework encourages continuous monitoring of networks and services, the physical environment, personnel activity, technology usage, external service providers, and computing hardware and software (NIST, 2024).

Some of these included using Microsoft Office 365 for phishing email and alerting, performing routine checks on equipment and software updates, ensuring the SIEM is updated and monitored, and configuring it to alert IT and Cybersecurity professionals to unusual events. The SIEM used to investigate emails is Microsoft Defender: emails and attack story, to check logins, and Splunk is used to monitor user logins. Happy Students Daycare has the responsibility to ensure that all information is secured and is commonly known to be targeted by spam mail. Though it may seem evident at first, as technology advances, phishing emails are becoming more sophisticated, and Happy Students Daycare needs to be ready for anything that comes their way.

Classification

Data breaches are common and can cause potential long-term damage to a company's reputation. When determining the severity and classification of a data breach, follow the guidelines below to decide the appropriate level:

- **Minor:** An internal isolated event that only involves one or more employees within the company. The data breach was made in error.
- **Moderate:** External or internal parties (threat actors, employees) seek data but do not successfully retrieve the data to sell or publish. In addition, these parties can only access data that does not compromise the company's reputation; therefore, no sensitive, highly protected, or confidential data was compromised.
- **Major:** Full data breach of sensitive, highly protected, or confidential data was compromised, sold, and published. This can damage the company's reputation and require immediate attention.

Information Gathering (Level 1 Response)

When gathering information to classify the data breach at the helpdesk or IT first responders' level, or third-party service providers. Happy Student Daycare is a small company with only 20 staff members; they are likely to use a third party. The following questions should be investigated before responding:

- Who is/ are the person of contact when there is a Data Breach?
- Who is involved in this data breach? Is this an internal data breach? Is it an unknown party involved (such as a customer or threat actor)?
- What devices are involved in this data breach? Was it a lost or stolen mobile device, a computer hardware issue, or a software issue?
- Where was the starting point of the data breach? Did it occur through a phishing email? Was it an unidentified malware? Was it an attack on our networks or website?
- Does the phishing email have any malicious links? If so, what is the nature of the link, where does it lead, and what does it ask for? Who is the target? Was it a scam? What was it advertising and why?
- Does the Malware have specific tasks? Did it exploit a vulnerability? What was its entry point?

Information Gathering (Level 2 Response)

At this level, Happy Students Daycare's first tech responder will gather information and send it to the third-party support team. From the information received from professionals or first tech respondents, the guidelines should be followed below:

- Does this meet the threshold of a moderate classification?
- Was this an external threat actor who performed the attack? What were their motives? How did it happen? Why did it happen?
- How can we improve our systems to prevent a similar attack? Where are the vulnerabilities and gaps in our security architecture?

Information Gathering (Level 3 Response)

At this point, the third party will take over completely while supporting Happy Student Daycare. From the information received from the prior levels, the guidelines should be followed below:

- Is this situation significant enough to be deemed major? Does the attack put customers at risk? Does the attack put staff at risk or both?
- What are the next steps in notifying the public? Which legal and governmental entities need to be notified?
- Do lawyers need to be involved, and how?
- How does this financially impact Happy Students Daycare? What are the services that impact customers?
- How much data has been compromised?

Escalation Decisions

Depending on the event's classification, follow the escalation guidelines below for continuity and documentation purposes. Regardless of the classification, all events should be documented.

- **Minor:** Any event within this category that poses an immediate risk to the company must follow the information gathering level 1 response and /or 2. A comprehensive report should be written about the event. In addition, the internal parties involved need to redo cybersecurity training and/ or speak with Happy Students Daycare's sole IT representative regarding their actions. This

may be done after work or at home, on the employee's own time, to ensure the smiley faces needed to ensure the safety and fun of our beloved customers.

- **Moderate:** Any event in this category should immediately be escalated to IT management. In a moderate situation, appropriate actions must be taken to address system vulnerabilities immediately to prevent them from escalating to a major classification event. In addition, a relevant department, such as the Daycare and HR head, should be involved if it involves a current employee.
- **Major:** Any event in this category is considered serious and needs to be escalated to IT, Management and the third-party Cybersecurity firm. In this case, all IT Management and the incident response team will respond to the event and address the needs appropriately. Once customers' data has been compromised, it is essential to notify the Canadian Centre for Cyber Security and the Information and Privacy Commissioner of Ontario, followed by PIPEDA and any necessary law enforcement. Seek out the bank's legal team.

Mitigation and Containment

Based on the classification, follow the recovery process. Refer to Appendix 1 for a workflow process.

Classification	Event	Recovery
Minor	A phishing email that caused no harm to the company.	Contain and ensure the identified phishing email is deleted from all staff inboxes.
Moderate	A phishing email caused harm when an employee clicked it. However, no signs of data loss or malware installation.	Ensure that all the phishing emails have been removed from all staff inboxes. Do a system check to ensure there was no malware installed, such as a Trojan, worms or viruses. Investigate origins and secure any vulnerabilities. Practice safe and secure cybersecurity practices. Update passwords with stricter rules. Also, notify the Cybersecurity firm immediately for backup. Conduct a mandatory phishing email awareness refresher and notify staff of the event.
Major	Any event, such as a phishing email, that breaches the confidentiality of Happy Students Daycare data, such as personal data, staff logins, and	Enter immediate recovery mode. Locate the breach. Restore backup information so that some services can be operational. Notify the third-

	sensitive company (customers') data.	party Cybersecurity firm immediately. Notify all leadership to call a meeting to discuss next steps. All data loss should be reported to Canadian Centre for Cybersecurity (CCCS). All privacy breaches must be reported to the Information and Privacy Commissioner of Ontario (IPC).
--	--------------------------------------	--

Pre-Approved Communication Templates

Email Communication for Minor Issues

Staff reporting phishing email to IT

Dear [Staff]

The message you have forwarded is indeed a phishing attempt.

Please delete the email from your inbox. You require no further action at this time.

Below is a list of things to look for when identifying a phishing email:

[Staff (Only: 1) All outside emails will have a disclaimer that does not originate inside the company banner.]

[Customer (Only: 1) All HSDC emails are sent to customers with a non-reply function]

2) All promotional HSDC emails are sent with a verified signature, and all links will lead you to our online banking home page.

3) When in doubt, email HSDC at happystudentsdaycare@outlook.com

If you have any questions or concerns, please let us know.

Sincerely,

HSDC IT

Employee reports a data breach concern

Dear [Staff name],

Thank you for your email. The HSDC IT will investigate the matter immediately.

You will hear from our representative regarding the next steps.

If you have any further questions or concerns, please let us know.

Sincerely,

HSDC IT

Email Communication for Moderate Tickets

Dear [staff],

Please be advised that we have experienced an incident that requires a system update. This system will be temporarily unavailable during [mention start date and end time].

Sincerely,

HSDC

For Customer Online Services, please add a banner on the online services to notify customers.

These services will be unavailable during these times [insert time]. For more information, [include link to Happy StudentDaycare]

Email Communication for High Tickets

Subject Line: ATTN: Important Security Notice

Dear [Staff, Management, CEO, all branches],

On [date] at [time], a significant security breach has impacted some of our services. Due to HSDC, we will contact each department with the required security steps. HSDC will be conducted at a hot site backup to ensure the smooth operation of our services. However, it will take some time to get everything back to normal

Due to the major incident, online banking will be suspended to avoid further complications until the problem is resolved.

During this time, as we work on a backup system, we ask that everyone be diligent when clicking on links from emails outside the company. Please look for the warning banner on each email as shown below:

WARNING!!! This email is from an outside sender. Respond with caution and be vigilant when clicking on links.

HSDC IT will keep you updated until the situation is resolved. If you have further questions and concerns, don't hesitate to get in touch with your manager or Team Lead or call us at (671)676-6767 ext. 2222 for any immediate issues.

Thank you for being so patient,

HSDC IT

Business Continuity Plan

Business continuity is essential to our Happy Students Daycare children and to our reputation; therefore, determining which sites are affected and what has happened is necessary. All sites should be on a centralized system, such as SharePoint, to ensure continuity.

Staff Communication:

If the centralized computer system is impacted, staff must still communicate without email. As a backup, all staff will use their personal mobile devices to communicate with each other when not in the Daycare, including phone calls or text messages. In addition, at all locations, a landline phone should be available for use at the Daycare to communicate. During this time, email use should be halted. Any staff schedules should be printed out for the time being, and the Management team will have to place them at each location. There should always be an updated phone book with all current staff numbers, location numbers, and Management, IT, and Parents numbers. This should be updated regularly and distributed to each location.

Customer (Child) Records:

All customers' data should be stored in the SharePoint cloud as a backup, accessible across all locations. In the event of a data breach, HSDC should maintain regular printouts of emergency contact information for each customer and weekly printouts of the customers who attend the daycare. Since digital sign-in is manual, manual attendance should be done until systems are restored. All parents should have the daycare's emergency contacts, including phone numbers and email addresses. In a system for their customers, an organized backup sign-in process is documented in a bookkeeping log, stored in an adequately secured location with extra copies.

Payment Method:

HSDC is an essential part of the Peterborough community, attracting new customers every day and currently requiring payments to sustain business operations, pay employees, and ensure our customers receive quality care. For the time being, it is essential to notify parents of our young customers about the issues. There also needs to be manual invoices and a payment process for parents, or a delayed payment plan.

Recovery and Return to Normal Operation

Recovery from a partial shutdown would take within 24 hours or 1 to 2 business days for everything to return to normal. This would require the full cooperation of all staff, HR, IT and parents so that our customers can enjoy their time carefree. Below is a step-by-step process for recovering the system:

Step 1: Assess all computers at all 12 locations for any signs of infection and isolate the infected computers.

Step 2: Verify the cloud and data integrity to see if anything has been affected

Step 3: If any data has been impacted, restore it from any backups immediately.

Step 4: Beginning paper-based operations at impacted locations, until further notice.

Step 5: IT, IT service providers and Cybersecurity service providers will collaborate to recover the process.

Step 6: Ensure parents are aware of the process and what is happening.

Step 7: Ensure all necessary systems have been cleaned and restored, including documents, SharePoint, and email, for all staff. Also, reset all staff passwords.

Step 8: Ensure the backup is recovered and that everything is running smoothly.

Step 9: Once everything has been cleared and is back to normal, confirm there is no malware left, and start using less paperwork.

Step 10: Hold staff meetings, conduct lessons learned sessions, and update policies to strengthen the security infrastructure.

These steps are guidelines for the recovery process and must be followed to ensure the safety of our customers and the reliability of our Daycare.

HAPPY STUDENTS' DAYCARE TABLETOP EXERCISE- PHISHING EMAIL

PART 3

Tabletop Objectives

Building Resilience

This Happy Students Daycare Tabletop Exercise Package aims to improve HSDC management teams' response time to phishing email incidents, making the organization more resilient and better prepared to handle real emergencies efficiently. This exercise will enable the CEO, Human Resources, IT and Lead staff to address gaps in their response to phishing emails.

To effectively build resilience, the objectives below need to be met:

- Examine the response of the Happy Students Daycare executive team during a spear phishing incident
- To evaluate the Happy Students Daycare collaboration effort during a phishing incident.
- Observe any areas for improvement
- Measure the awareness and compliance of the security policies.
- To reduce vulnerability to real-world phishing attacks.

Exercise Structure

This exercise uses a lab simulation of phishing emails. Participants will participate in the following:

- Cyber Threat briefing
- Scenario:
 - This scenario is an evaluation of phishing email examples
 - This scenario is an evaluation of the steps taken to deal with the event
- Discussion:
 - In teams, answer questions related to the exercise
- Injections and need to answer questions and resolve the new incidents(optional)
- Hotwash to conclude the exercise

Exercise Guidelines

This section outlines the facilitators' and participants' expectations during the Tabletop Exercise. It must be clear that it is a safe space for participants to share their thoughts and experiences. Furthermore, this exercise requires collaboration to simulate a real situation. The expectations are outlined below:

- This exercise is designed for a safe space where participants can be open; it is a no-fault environment. Different opinions will be expressed, and respect is necessary for a successful exercise.
- Approach the scenario using your previous knowledge of current plans and capabilities and various insights from your experience.
- Your approach to the scenario will not set a precedent for your organization or individual capabilities. This exercise allows your organization to discuss, investigate, and practice together to resolve and mitigate future problems.
- All the resources provided are meant for discussion and training to improve security response. This scenario will be used with the assumptions of play to understand the procedure. Your participation is vital to your learning and acquisition.
- Have fun and be respectful to your colleagues. Teamwork is crucial to any incident response, so collaboration is key.

Incident Response Participants

Participants will participate in the discussion and perform the exercise. The list of participants is below:

- Chief Executive Officer x1
- Chief Human Resources Officer x1
- Head of Information and Technology (IT) x1
- Team Lead Daycare staff x 2

Observers will passively observe the tabletop exercise. They can help shape participants' responses, but they are not required to do so. They do not initiate any action in the exercise. The list of Observers is below:

- IT Services providers x1
- Cybersecurity Services provider x1
- Daycare staff members x 5

Facilitators will provide the scenario, moderate discussions, and ensure all rules are followed. Members of the planning team will assist with facilitating the exercise. The list of facilitators is below:

- Author/ Trainer
- Cybersecurity Team Lead from a third party
- 1 Member from the training team

Note-takers (optional) observe and record the exercise activities and participants' perceptions of the exercise. They also monitor participants' understanding of the activity.

- Members from the planning team

Exercise Overview

Phishing Email		
Exercise Date, Time, and Location	Date: Monday, December 15, 2025, Time: 9:00 am-12:10 pm Location: HSDC Training Room	
Exercise Activities	Time	Activity
	20 Minutes	Introduction, opening remarks, threat briefing
	60 Minutes	Scenario Overview (**20- 30 minutes is a good time to add in an inject**)
	20 minutes	Break
	40 minutes	Present Scenario overview solution to the facilitator
	15 minutes	Break
	30 minutes	Hotwash
Purpose	To examine how well the HSDC can handle a phishing attack.	
Objectives	1. Examine the response of HSDC during a phishing incident 2. To evaluate the HSDC collaboration effort during a phishing incident. 3. Observe any areas for improvement 4. Measure the awareness and compliance of the security policies. 5. To reduce vulnerability to real-world phishing attacks.	
Threat or Hazard	Phishing Email Attack (Spear Phishing Attack)	
Scenario	HSDC's executive team received an email from the Head of IT about a new initiative to improve password security: everyone must change their password every month. The email states that it is being launched today to reset your password. One of the HSDC staff members clicks on the link, which brings them to a legitimate-looking HSDC reset password page. It asks for the username, the old password, the new password, and the retype password. The executive team member enters their new credentials but realizes the password did not change after submitting it. After several attempts, the HDSC Staff member decides to contact the Head of IT. The Head of IT has informed the executive team member that no such initiative has been launched. Within hours, the Cybersecurity analyst team noticed increased traffic, and the system was flooded, leading to a data breach and the installation of a virus on HDSC computers at all 12 locations. This impacted payments and children's online sign-in.	
Sponsor	HSDC Institution of Canada	
Participating	HSDC Participants (Refer to page 19)	

Scenario Overview

Scenario

HSDC's executive team received an email from the Head of IT about a new initiative to improve password security: everyone must change their password every month. The email states that it is being launched today to reset your password. One of the HSDC staff members clicks on the link, which brings them to a legitimate-looking HSDC reset password page. It asks for the username, the old password, the new password, and the retype password. The executive team member enters their new credentials but realizes the password did not change after submitting it. After several attempts, the HSDC Staff member decides to contact the Head of IT. The Head of IT has informed the executive team member that no such initiative has been launched. Within hours, the Cybersecurity analyst team noticed increased traffic, and the system was flooded, leading to a data breach and the installation of a virus on HSDC computers at all 12 locations. This impacted payments and children's online sign-in.

*** Appendix E: There is an overview of the injection scenario; this is optional***

Technical Information

- All company computers are on the same cloud server and can be accessed by the IT and Cybersecurity third-party servers. The IT department has recommended that all saved documents be stored in the cloud for backup, and that access to the cloud require MFA.
- A known hacktivist group, "S@v3thēchildrən", carried out the attack. They have been known to use spear-phishing attacks against organizations like HSDC, such as schools, to obtain confidential organizational information.

Phishing Emails Instructions (Facilitator Only)

- The facilitator should review the expectations and the scenario with the participants and answer any questions before starting.
- Appendix A: Scenario (print)
- ***Appendix B: Has the injection Scenario and discussion questions
- Appendix C: Email Sample (print)
- Hand out copies to the participants.
- Read the discussion questions and explain to the participants that they need to go through each discussion question and develop an efficient plan to be presented to the facilitator assigned to their team.
- Hand out two copies of the Discussion questions to each team.
- Appendix D: Discussion Questions (print)
- Appendix E: Login Page Sample

Discussion Questions

Discussion questions are included to explore aspects of organizational resilience. The questions can be modified. Printable discussion questions are found in Appendix D.

1. What kinds of cyber threats could affect our daycare?
2. Have you heard of daycares or schools being hacked?
3. What happened in this scenario?
4. What were some of the red flags in this scenario?
5. What day-to-day operation was impacted because of this problem?

6. Tell us how you would handle this situation at HSDC?
7. When you notice something off, what would you do to stop and get help? Who would you contact?
8. What is the problem, and why is this serious?
9. Looking at the email, what is wrong with it?
 - a. What do you notice that makes it a phishing email?
 - b. Are there any misspelled words or information?
 - c. Is this email urgent and needs action now?
 - d. What is the email asking you to do?
 - e. Does the ask for any personal information from you?
10. Why do you think the HSDC staff member clicked on the email link?
 - a. Was the person rushing or stressed when checking their email?
 - b. Have you ever almost clicked on something similar? What stopped you?
11. If this were to happen to you and your team, would you feel ready?
 - a. When was the last time you talked about cybersecurity as a team?
 - b. Can you explain what a phishing email is in your own words?
12. How would you tell everyone in daycare about the problem?
 - a. How would you tell the staff? How should the staff be told?
 - b. How would you tell the parents?
 - c. How do you tell insurance companies?
 - d. How do we tell third-party services?
 - e. How would you handle children's information?
13. What could have prevented this from happening?
14. What can the team do differently to prevent this scenario from happening? What does that look like?

Facilitator Notes and Response Plan to Scenario

Aspect	Response Information	Notes
Immediate Situation Control	The IT department should be notified immediately of the incident. All work and access should be halted and shut down to ensure nothing else is compromised.	HR need to outline the protocol for working offline to staff. Staff should be notified to disable access to systems.
Cyber Insurance	The insurance company should be notified, as there will be a shutdown.	The insurance company can offer some support.
Legal Response	The organization's legal team should be notified, as documents have been stolen. ***Potential political motivation, the legal team will need to take a different approach.	The insurance team provides information about the services they offer, including forensic services. The legal team needs to notify the right ministers *** The legal team needs to prepare for lawsuits.
Privacy Protection	Look at the privacy implications. There was a data breach, and now the hacker has sensitive information. ***Legal response is not only a data breach but a privacy breach.	The CEO should give more information about the privacy breach. This must be reported to the Legal departments in your Region and Country. For

		example, the Ontario Privacy Commission.
Forensic Response	The insurance company will support the cybersecurity team in collecting evidence regarding the attacker. The executive team will be constantly updated on the next steps.	The organization has a Cybersecurity team that will work with the Insurance company.
Continuing Operations	Operational areas, such as the executives' roles and any other area of the company, that have been affected should be modified securely.	
Additional Security Response	The IT team should change the password, and the employees should come to the office in person to avoid confusion.	The Public relations team should be the ones sending and communicating this.
Communication Plan	This plan needs to be implemented according to the severity. Since the executive member's account was hacked and data was stolen, prompt internal communication is necessary. *** Needs to be public and work closely with the communication team when needed to talk to the media.	

Hot Wash/After Action review

The Hot Wash session is an opportunity for open discussion. It is a time for everyone in the room to give feedback and discuss what they have learned. Also, this is an excellent time for facilitators to take notes on the participants' responses. Below are a few questions to help guide the conversation:

1. What went well during the exercise?
2. How did the exercise make you feel?
 - a. Do you feel more prepared?
 - b. Do you feel less prepared?
 - c. On a scale of 1-10 (1 being not prepared at all – 10 being very prepared)?
3. What did you learn?
4. Are there other issues or concerns you'd like to discuss that weren't raised?
5. What aspects of our plan require the most immediate attention?
6. How can we improve future exercises?
7. What did you like about the exercise?

After Action Report (Facilitators Only)

After the session, come together and write a report on the hot wash and the exercise. This should help with future exercises and make any necessary improvements. The document should be sent to the Trainer within one week of the tabletop exercise completion date. The report should include:

- Best practices
- Improvements
- Feedback from notetakers
- Hot wash
- What went well and what did not go well
- Any additional information on the improvement of the exercise.

References

Kaspersky. (2025). *What is data breach? How to prevent data leaks.*

Kaspersky. <https://www.kaspersky.com/resource-center/definitions/data-breach>

Kosinski, M. (2025). What is a data breach? IBM. <https://www.ibm.com/think/topics/data-breach>

NIST. (n.d.). *The NIST Cybersecurity Framework (CSF) 2.0.*

<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

Microsoft Intune. (2025, March 3). *What does device management mean for organizations?* Microsoft Intune.

<https://learn.microsoft.com/en-us/intune/intune-service/fundamentals/what-is-device-management>

Appendix A

Scenario:

HSDC's executive team received an email from the Head of IT about a new initiative to improve password security: everyone must change their password every month. The email states that it is being launched today to reset your password. One of the HSDC staff members clicks on the link, which brings them to a legitimate-looking HSDC reset password page. It asks for the username, the old password, the new password, and the retype password. The executive team member enters their new credentials but realizes the password did not change after submitting it. After several attempts, the HDSC Staff member decides to contact the Head of IT. The Head of IT has informed the executive team member that no such initiative has been launched. Within hours, the Cybersecurity analyst team noticed increased traffic, and the system was flooded, leading to a data breach and the installation of a virus on HDSC computers at all 12 locations. This impacted payments and children's online sign-in.

Appendix B

***Inject Scenario

These are additional questions the team can discuss and provide responses to. They can role-play these scenarios.

- **Scenario one:** A parent heard about the news and called to find out about the hack that they heard happened at the Daycare.
 - Roles: one person can be the parent and the other the staff
- **Scenario two questions:** What are some things that you would do right now if you did not have access to the children's files?
- **Scenario three questions:** You notice something suspicious on the computer. What would you do?

Appendix C

ATTN: Change in Password Policy

From: HDSC <[happystudent\\$daycare@outlook.com](mailto:happystudent$daycare@outlook.com)>
To: All Staff

  Reply  Reply all  Forward  

Thu 2025-10-16 2:29 PM

WARNING!!! This email is from an outside sender. Respond with caution and be vigilant when clicking on links.

Dear HDSC Staff,

We are excited to announce that the HDSC Head of IT have developed a new password protocol for enhanced security. This initiative requires all staff to change their passwords monthly.

This new security initiative is to be implemented immediately. Please click the link below to change your password and read the new policy. This needs to be done by the end of the day today.

[HSDC Change Here](#)

If you have any questions, don't hesitate to contact us.

Thank you,
HSDC IT



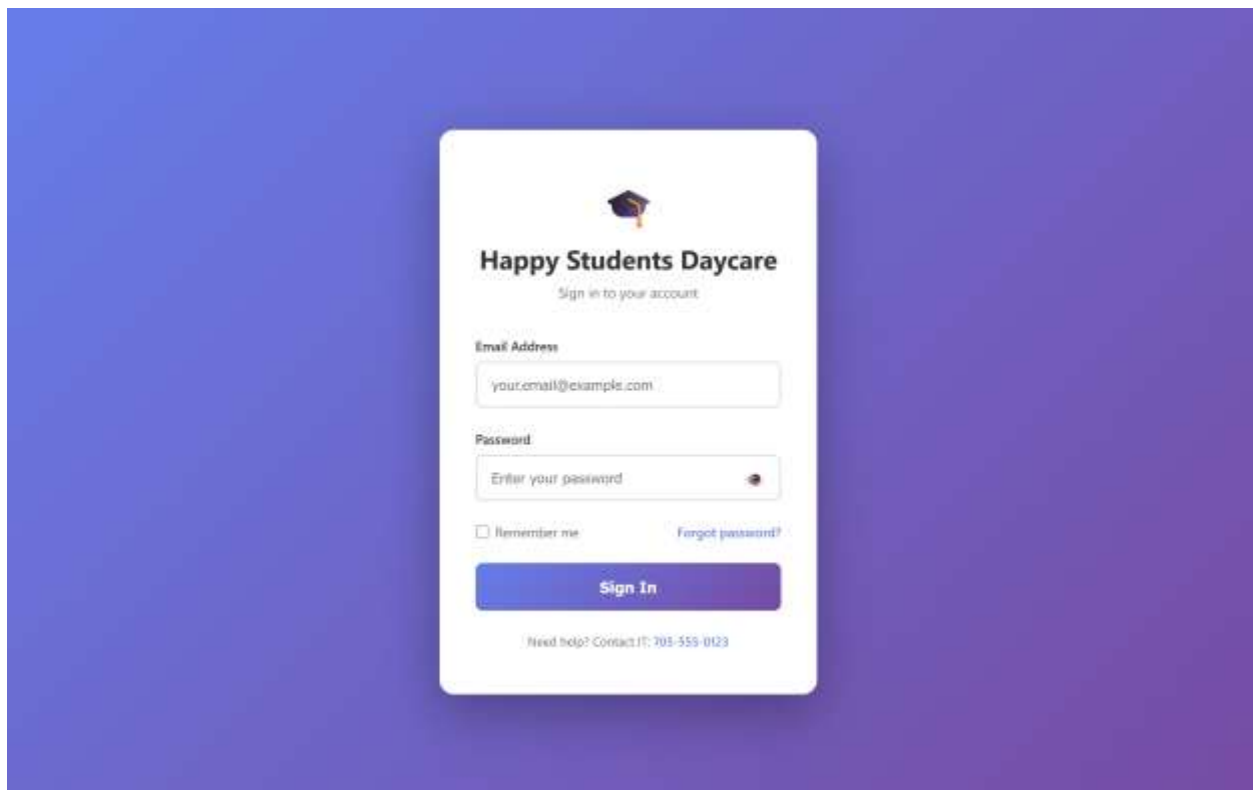
 Reply  Reply all  Forward

Appendix D

Discussion questions are included to explore aspects of organizational resilience. The questions can be modified. Printable discussion questions are found in Appendix D.

1. What kinds of cyber threats could affect our daycare?
2. Have you heard of daycares or schools being hacked?
3. What happened in this scenario?
4. What were some of the red flags in this scenario?
5. What day-to-day operation was impacted because of this problem?
6. Tell us how you would handle this situation at HSDC?
7. When you notice something off, what would you do to stop and get help? Who would you contact?
8. What is the problem, and why is this serious?
9. Looking at the email, what is wrong with it?
 - a. What do you notice that makes it a phishing email?
 - b. Are there any misspelled words or information?
 - c. Is this email urgent and needs action now?
 - d. What is the email asking you to do?
 - e. Does the ask for any personal information from you?
10. Why do you think the HSDC staff member clicked on the email link?
 - a. Was the person rushing or stressed when checking their email?
 - b. Have you ever almost clicked on something similar? What stopped you?
11. If this were to happen to you and your team, would you feel ready?
 - a. When was the last time you talked about cybersecurity as a team?
 - b. Can you explain what a phishing email is in your own words?
12. How would you tell everyone in daycare about the problem?
 - a. How would you tell the staff? How should the staff be told?
 - b. How would you tell the parents?
 - c. How do you tell insurance companies?
 - d. How do we tell third-party services?
 - e. How would you handle children's information?
13. What could have prevented this from happening?
14. What can the team do differently to prevent this scenario from happening? What does that look like?

Appendix E



A login form for 'Happy Students Daycare' is centered on a blue-to-purple gradient background. The form is white with rounded corners and a subtle shadow. At the top of the form is a graduation cap icon. Below the icon is the text 'Happy Students Daycare' in bold, followed by 'Sign in to your account' in a smaller font. The form contains two input fields: 'Email Address' with the placeholder 'your.email@example.com' and 'Password' with the placeholder 'Enter your password'. Below the password field are two links: 'Remember me' with an unchecked checkbox and 'Forgot password?'. A blue 'Sign In' button is positioned below these links. At the bottom of the form is a link that reads 'Need help? Contact IT: 705-555-0123'.



Happy Students Daycare

Sign in to your account

Email Address

your.email@example.com

Password

Enter your password

☐ Remember me [Forgot password?](#)

Sign In

[Need help? Contact IT: 705-555-0123](#)